

SOC 2 Trust Services Criteria

Every criterion across all five Trust Services Categories — Security, Availability, Confidentiality, Processing Integrity, and Privacy — with what each requires and the evidence auditors typically request.

51	33	5	9
CRITERIA TOTAL	COMMON (SECURITY)	TSC CATEGORIES	CC SERIES (CC1–CC9)

Framework basis: AICPA TSP Section 100 — Trust Services Criteria (2017, with 2022 revised points of focus), derived from the COSO Internal Control–Integrated Framework (2013). • **Prepared:** 30 July 2026 • Study & pre-audit reference.

✓ Criterion names, COSO mappings, and category structure verified against the primary AICPA TSP Section 100 source text.

How SOC 2 is structured

Criteria, not a fixed control list. The AICPA defines **criteria** you must meet; **you design the controls** that satisfy them and produce the evidence an auditor tests. SOC 2 does not prescribe specific algorithms, key lengths, or password rules — controls must be **risk-based, documented, implemented, and (for Type 2) shown to operate across the whole observation period.**

Category	Criteria	Focus — the question the auditor is answering
Security (mandatory)	CC1–CC9 33 criteria	Is information and are systems protected against unauthorized access, disclosure, and damage? The Common Criteria — required in every SOC 2 report.
Availability	A1.1–A1.3	Are systems available for operation and use as committed in contracts / SLAs (capacity, backup, recovery)?
Confidentiality	C1.1–C1.2	Is information designated as confidential protected throughout its lifecycle, including secure disposal?
Processing Integrity	PI1.1–PI1.5	Is system processing complete, valid, accurate, timely, and authorized?
Privacy	P1–P8	Is personal information collected, used, retained, disclosed, and disposed of in line with commitments (GDPR / CCPA-aligned)?

Type 1 vs Type 2. A **Type 1** report tests whether controls are *suitably designed* at a point in time. A **Type 2** report tests whether they *operated effectively* across an observation period (commonly 3–12 months) — so every control needs evidence spanning the period, not a single screenshot. The first five CC series (CC1–CC5) map to the 17 COSO principles; CC6–CC9 add technology-specific criteria.

CC1 — Control Environment

The governance foundation: integrity, board oversight, organizational structure, competence, and accountability. Maps to COSO Principles 1–5.

ID		What it requires	Typical evidence
CC1.1	Integrity & ethical values	Demonstrate commitment to integrity and ethics; set tone at the top; address deviations from conduct standards promptly.	Code of conduct; ethics policy; signed acknowledgements; disciplinary process.
CC1.2	Board oversight	Board / governing body operates independently and oversees the development and performance of internal control.	Board charter; meeting minutes; independence documentation; security oversight records.
CC1.3	Structure & authority	Management establishes structures, reporting lines, and appropriate authorities and responsibilities.	Org chart; roles & responsibilities; RACI; job descriptions.
CC1.4	Commitment to competence Training in scope	Attract, develop, and retain competent individuals; provide security training; plan succession.	Training policy & curriculum; per-person completion records; competency / hiring criteria.
CC1.5	Accountability	Hold individuals accountable for their internal-control responsibilities, with consequences for failures.	Performance reviews; accountability in job descriptions; policy-acknowledgement records.

CC2 — Communication & Information

How quality information is generated and communicated internally and externally to support internal control. Maps to COSO Principles 13–15.

ID		What it requires	Typical evidence
CC2.1	Quality information System diagram	Obtain / generate and use relevant, quality information to support control operation. (System-boundary <i>communication</i> points of focus sit under CC2.2 / CC2.3 at system level; the diagram artifact itself is primarily governed by the Description Criteria.)	System description; network / data-flow diagrams; asset inventory.
CC2.2	Internal communication Training · Cust. email	Communicate objectives and control responsibilities internally, including security policies and how to report issues.	Published policies; training; intranet; internal reporting / whistleblower channel.
CC2.3	External communication Cust. email	Communicate with external parties (customers, vendors) about objectives and responsibilities, including a channel to report concerns.	Customer security / trust page; contact & escalation process; vendor communications; ToS / DPA.

CC3 — Risk Assessment

Setting objectives and identifying, analyzing, and responding to risk — including fraud and change. Maps to COSO Principles 6–9.

ID		What it requires	Typical evidence
CC3.1	Specify objectives	Specify objectives with enough clarity to enable identification and assessment of risks to those objectives.	Documented business / security objectives; risk-assessment scope.
CC3.2	Identify & analyze risk	Identify risks to objectives across the entity and analyze them as a basis for how they should be managed.	Risk assessment; risk register with likelihood / impact scoring; treatment plans.
CC3.3	Fraud risk	Consider the potential for fraud in assessing risks to the achievement of objectives.	Fraud-risk review; documented fraud scenarios in the risk register.
CC3.4	Changes affecting controls	Identify and assess changes (business, tech, personnel) that could significantly impact the system of internal control.	Change-triggered risk reviews; re-assessment on major system / org changes.

CC4 — Monitoring Activities

Ongoing and separate evaluations to confirm controls are present and functioning, and communicating deficiencies. Maps to COSO Principles 16–17.

ID		What it requires	Typical evidence
CC4.1	Ongoing / separate evaluations Vuln scans	Select, develop, and perform ongoing and/or separate evaluations to ascertain whether controls are present and functioning.	Internal audits; control self-assessments; vulnerability scans; penetration tests.
CC4.2	Evaluate & communicate deficiencies	Evaluate and communicate control deficiencies in a timely manner to parties responsible for corrective action.	Findings tracker; remediation tickets with owners & dates; management reporting.

CC5 — Control Activities

Selecting and deploying control activities — including technology general controls — through policy and procedure. Maps to COSO Principles 10–12.

ID		What it requires	Typical evidence
CC5.1	Select control activities	Select and develop control activities (a mix of preventive / detective, manual / automated) that mitigate risks to acceptable levels.	Control matrix mapping risks to controls; policy set.
CC5.2	Technology general controls	Select and develop general control activities over technology to support achievement of objectives.	Access, change, and operations control documentation; IT general controls.
CC5.3	Deploy via policy	Deploy control activities through policies that establish expectations and procedures that put them into action.	Approved policies & procedures; review / version history; acknowledgements.

CC6 — Logical & Physical Access Controls

The largest CC series — where most audit hours land. Covers access security, provisioning, physical access, boundary protection, transmission, and malicious-software defense.

ID		What it requires	Typical evidence
CC6.1	Logical access security Data · Creds · Prod · Envs · Remote	Implement logical access software, infrastructure, and architectures over protected assets; includes asset inventory, authentication, segmentation, encryption, and key management.	Access-control policy; SSO/IdP config; MFA; encryption config; firewall rules; asset inventory.
CC6.2	User registration & deprovisioning Credentials	Register and authorize new users before granting access; remove access when no longer authorized; review access periodically.	Onboarding / offboarding tickets; dated access reviews with approvers; provisioning records.
CC6.3	Role-based access Creds · Prod	Authorize, modify, or remove access to data and functions based on roles, responsibilities, and least privilege.	RBAC export; role definitions; access-change approvals.
CC6.4	Physical access	Restrict physical access to facilities and protected information assets (data centers, backup media, offices).	Badge logs; visitor logs; data-center provider SOC 2; server-room access list.
CC6.5	Secure decommissioning	Discontinue logical & physical protections over assets only after data has been rendered unrecoverable (secure disposal / wipe).	Media-sanitization / destruction records; asset-retirement logs; certificates of destruction.
CC6.6	Boundary protection Remote MFA	Implement measures against threats from outside the system boundary; additional authentication (MFA) for external access; firewalls / IDS.	MFA-enforcement proof per external system; VPN / zero-trust config; firewall & IDS configs.
CC6.7	Data transmission & movement Data in transit · Remote	Restrict and protect information during transmission, movement, and removal (encryption in transit, DLP, removable-media controls).	TLS scan; DLP config & alerts; removable-media policy; transfer logs.
CC6.8	Malicious software Patching	Prevent or detect and act upon the introduction of unauthorized or malicious software.	EDR / antivirus config; file-integrity monitoring; allowlisting; patch evidence.

CC7 — System Operations

Day-to-day security operations: vulnerability detection, monitoring, and the full incident lifecycle (evaluate → respond → recover).

ID		What it requires	Typical evidence
CC7.1	Vulnerability detection Vuln scans · Patching	Use detection / monitoring procedures to identify config changes introducing vulnerabilities and susceptibilities to newly discovered ones; conduct vulnerability scans.	Scan schedule & reports; config baselines (CIS); remediation tracking within SLA.
CC7.2	Security event monitoring	Monitor system components for anomalies and indicators of security events.	SIEM / log monitoring; alerting rules; log-coverage evidence.
CC7.3	Evaluate security events	Evaluate security events to determine whether they constitute security incidents.	Triage records; incident-classification criteria; event review logs.
CC7.4	Incident response	Respond to identified security incidents through a defined program (contain, remediate, communicate).	Incident-response plan; incident tickets; post-incident reviews; breach-notification process.

ID		What it requires	Typical evidence
CC7.5	Recovery	Identify, develop, and implement activities to recover from identified security incidents.	Recovery procedures; root-cause analyses; tabletop-exercise records.

cc8 — Change Management

A single, heavily tested criterion governing the full change lifecycle for infrastructure, data, software, and procedures.

ID		What it requires	Typical evidence
CC8.1	Change management SW/HW · Restricted · Approved · Envs	Authorize, design, develop / acquire, configure, document, test, approve, and implement changes to infrastructure, data, software, and procedures. (Segregation of duties and environment separation are accepted <i>implementation controls</i> mapped here, not named sub-criteria in the CC8.1 text.)	Change-mgmt policy; PRs with reviewer approvals; CI test evidence; release notes; IaC history; env-separation config.

cc9 — Risk Mitigation

Mitigating risk from business disruptions and from vendor / business-partner relationships.

ID		What it requires	Typical evidence
CC9.1	Business disruption mitigation	Identify, select, and develop risk-mitigation activities for disruptions (business continuity, disaster recovery, insurance).	BC/DR plan; insurance (cyber / E&O); tabletop-exercise records.
CC9.2	Vendor & partner risk	Assess and manage risks associated with vendors and business partners.	Vendor inventory; security reviews / SOC 2s of critical vendors; DPAs; periodic re-assessment.

A1 — Availability (optional category)

Ensures systems are available for operation and use as committed. Added on top of the Common Criteria when uptime is a customer commitment.

ID	Criterion	What it requires	Typical evidence
A1.1	Capacity management	Maintain, monitor, and evaluate current processing capacity and use of resources to meet demand.	Capacity / performance monitoring dashboards; autoscaling config; forecasting.
A1.2	Environmental & backup protections Retention/Backups	Provide environmental protections, backups, and recovery infrastructure to meet availability objectives.	Backup policy & logs; offsite / geo-redundant storage; redundancy / failover config.
A1.3	Recovery testing Retention/Backups	Test recovery-plan procedures supporting system recovery to meet objectives (RTO / RPO).	Dated restore-test results; DR tabletop / failover drill records; RTO/RPO definitions.

C1 — Confidentiality (optional category)

Protects information designated confidential (IP, business plans, sensitive customer data) throughout its lifecycle, including disposal.

ID	Criterion	What it requires	Typical evidence
C1.1	Identify & protect Data at rest	Identify and maintain confidential information to meet the entity's confidentiality objectives (classification, access restriction, encryption).	Data-classification policy; encryption at rest / in transit; access restrictions; NDAs.
C1.2	Disposal Retention/Backups	Dispose of confidential information to meet objectives when no longer needed (retention limits + secure disposal).	Retention schedule; deletion / disposal logs; sub-processor deletion attestations.

PI1 — Processing Integrity (optional category)

Ensures system processing is complete, valid, accurate, timely, and authorized — from input through storage. Common for payments, data-processing, and financial platforms.

ID	Criterion	What it requires	Typical evidence
PI1.1	Processing definitions	Obtain / generate and use information about processing objectives and specifications (what "correct processing" means).	Data-processing specs; data-quality definitions; product / API documentation.
PI1.2	Input controls	Inputs are complete, accurate, and timely, in line with objectives.	Input validation rules; error handling; rejected-record logs.
PI1.3	Processing controls	Processing is complete, valid, accurate, timely, and authorized.	Processing logs; job-completion monitoring; authorization checks.
PI1.4	Output controls	Outputs are complete, accurate, and timely, and delivered to authorized parties (end-to-end reconciliation).	Output reconciliation reports; delivery / distribution logs.

ID	Criterion	What it requires	Typical evidence
PI1.5	Storage controls	Store inputs and outputs completely, accurately, and timely, per objectives.	Storage integrity checks; checksums / hashing; backup-integrity evidence.

P1–P8 — Privacy (optional category)

Governs the full lifecycle of personal information (PII). Carries the most criteria of any optional category; controls align closely with GDPR and CCPA obligations.

ID	Criterion	What it requires	Typical evidence
P1	Notice	Provide notice about privacy practices — how personal information is collected, used, retained, and disclosed.	Privacy notice with version control; publication records.
P2	Choice & consent	Give individuals choice regarding collection, use, and disclosure of their personal information, and obtain consent.	Consent-capture mechanism; consent logs; preference center.
P3	Collection	Collect personal information only for the purposes identified in the notice, limited to what is necessary.	Data-collection inventory; data-minimization records; lawful-basis mapping.
P4	Use, retention & disposal	Limit use of personal information to stated purposes; retain only as long as needed; dispose of securely.	Retention schedule; deletion logs; purpose-limitation controls.
P5	Access	Enable individuals to access, review, and correct their personal information (data-subject requests).	DSAR workflow with SLA tracking; access / correction request logs.
P6	Disclosure & notification	Disclose personal information to third parties only for identified purposes and with consent; notify of unauthorized disclosure.	Third-party / sub-processor register; DPAs; breach-notification procedure.
P7	Quality	Maintain accurate, complete, and relevant personal information for the purposes of its use.	Data-accuracy / correction processes; quality-check records.
P8	Monitoring & enforcement	Monitor compliance with privacy policies and procedures and address inquiries, complaints, and disputes.	Privacy-complaint log; compliance monitoring; enforcement / remediation records.

Building an evidence package (per control)

Assemble each control's evidence in this shape — it mirrors how an external auditor tests: confirm a documented control exists, verify implementation, inspect objective evidence that it operated during the period, and evaluate any exceptions.

Package item	What to include
Control name	The control being tested (e.g. "Restricted Changes to Production").
Criteria mapping	The TSC criterion / criteria it satisfies (e.g. CC6.1, CC6.3, CC8.1).
Policy	The governing policy document(s).
Technical verification	The concrete configuration state proving the control is live.
Evidence	Dated, objective artifacts — reports, screenshots, logs, exports, tickets.
Control owner	The accountable role.
Evidence date	Capture date — must fall within the observation period for Type 2.
Status	Pass / Gap.
Findings & remediation	Any exception, plus owner and due date to close it.

Where audits most often fail — watch-list

- **Logical access (CC6)** and **change management (CC8)** are the most heavily tested and the most common sources of qualified opinions.
- **Undated access reviews (CC6.2 / CC6.3)**: reviews happen informally with no artifact showing who was reviewed, who approved, and what changed.
- **Advisory-mode MFA (CC6.6)**: if a user can skip or disable MFA, the control is treated as not in place.
- **Untested DR (A1.3)**: a backup policy with no documented restore test is the single most common Availability gap.
- **Unapproved / retro-approved changes (CC8.1)**: any change reaching production outside the review workflow is a hard-to-explain exception.
- **Incomplete training records (CC1.4)**: no per-employee completion evidence for the full period, or contractors / late-period hires excluded.
- **Vulnerability closure (CC7.1)**: teams fix issues but can't prove closure with a dated re-scan tied to the original finding.
- **Processing Integrity (PI1.4)**: missing end-to-end reconciliation proving output matches input across the full pipeline.
- **Confidentiality disposal (C1.2)**: unverified de-identification / deletion claims; keep deletion logs and sub-processor attestations.

Authoritative source for the audit record: AICPA TSP Section 100 — *Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* (2017, with 2022 revised points of focus), derived from the COSO Internal Control–Integrated Framework (2013). "Points of focus" are implementation guidance the auditor uses to exercise judgment — they are not themselves mandatory line items.

This document is an internal study and pre-audit preparation aid. It does not constitute an audit opinion, certification, or legal advice. **Criterion counts:** 33 Common (CC1–CC9) + Availability (3) + Confidentiality (2) + Processing Integrity (5) + Privacy (8 series) = 51. **Note:** the Privacy figure counts each P-series as one; at the individual sub-criterion level (P1.1, P3.1–3.2, P4.1–4.3, P5.1–5.2, P6.1–6.7, etc.) the granular Privacy count is ~18, bringing the full criterion total to roughly 61.